



SPR01_침해사고 대응 매뉴얼_Ver 1.0

소관부서 : 정보보안팀

버전: Ver 1.0

I. 개요

1. 목적
2. 적용범위
3. 용어의 정의
4. 관련 규정 및 법규

II. 침해사고 대응 체계 및 조직

1. 침해사고 대응 체계도
2. 침해사고 대응 조직 구성
3. 비상연락체계

III. 침해사고 탐지 및 분석

1. 침해사고 신고 및 접수
2. 침해사고 대응조직 소집
3. 침해사고 신고 및 보고
4. 침해사고 상황전파

IV. 침해사고 대응 및 복구

1. 침해사고 대응 조치
2. 침해사고 복구
3. 침해사고 기록 및 보고

V. 침해사고 종결 및 보고

1. 상황 종결
2. 후속 조치

VI. 침해사고 유형별 대응 시나리오

1. 침해사고 유형
2. 침해사고 유형별 대응 시나리오

VII. 참고사항

- 관련 법규 상세 내용

I. 개요

1. 목적

본 매뉴얼은 침해사고 지침 및 IT재해복구 지침에 따라 주식회사 모인(이하 “회사”라 한다)의 침해사고 및 IT재해 대응 조직 구성과 역할 및 책임, 침해사고 및 IT재해 유형별 대응 시나리오를 수립함으로써 침해

행위에 대한 예방과 대응을 효과적으로 수행하는데 그 목적이 있다.

2. 적용범위

회사의 정보처리시스템 및 정보통신망을 대상으로 업무연속성 확보 및 장애·보안사고 발생이 확인되었거나 의심스러운 징후가 발견될 경우 분석, 대책 마련을 위한 모든 영역에 본 매뉴얼을 적용하며, 아래의 범위를 포함한다.

- 회사가 운영하는 정보시스템의 장애, 보안사고 발생으로 인해 서비스를 이용하는 고객이 영향을 받을 경우
- 모니터링 및 신고(서비스를 제공받는 주체 및 내부 임직원)에 의해 문제점으로 인식하고 분석, 조치 등의 후속조치가 필요한 경우
- 회사의 중요정보 및 개인정보가 유출되거나 훼손 등의 침해사고가 발생되었거나, 의심스럽다고 인지된 경우

3. 용어의 정의

“침해사고”란 <정보통신망 이용촉진 및 정보보호 등에 관한 법률 제2조1항7호> 해킹, 컴퓨터 바이러스, 트로이 목마, 백도어, 서비스 공격거부, 악의적인 공격 스크립트 등을 유포, 설치 및 실행으로 피해를 유발하는 악성코드 공격, 비 인가된 시스템 접근 및 파일접근, 네트워크 정보수집을 포함한 비 인가된 네트워크 정보 접근, 네트워크 서비스의 취약점을 이용하여 서비스를 무단 이용하는 비 인가된 서비스 이용, 네트워크 및 시스템의 정상적인 서비스를 마비 또는 파괴시키는 서비스 방해 등의 전자적 침해 사고를 의미한다.

4. 관련 규정 및 법규

1. 관련 규정

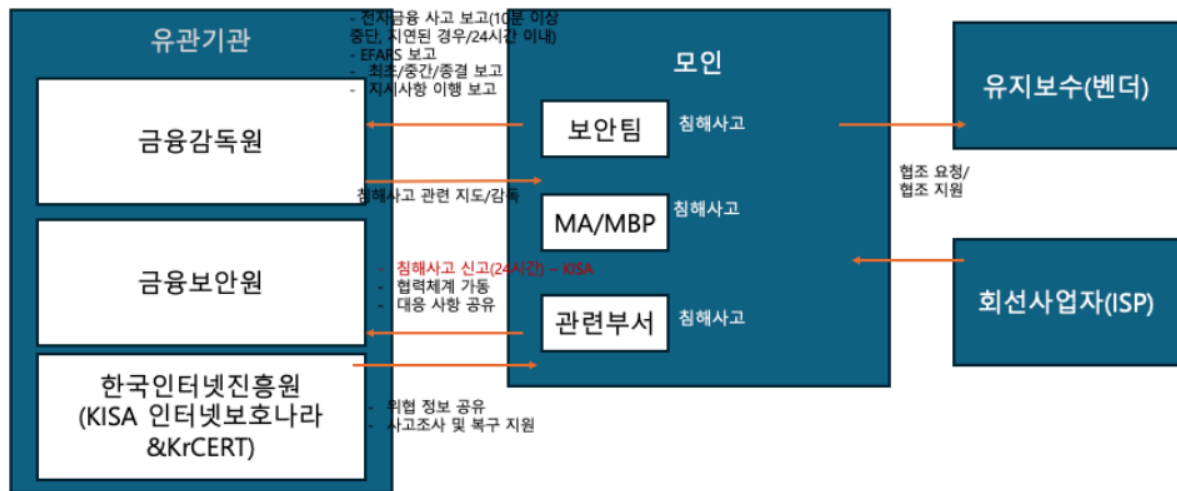
- a. 침해사고 대응 지침 제3장 침해사고 대응 체계
- b. 침해사고 대응 지침 제4장 침해사고 대응

2. 관련 법규

- a. 전자금융감독규정 제37조의5(정보기술부문 및 전자금융 사고보고)
- b. 전자금융감독규정 제 37조의6(침해사고대응기관 지정 및 업무범위 등)
- c. 전자금융감독규정시행세칙 제7조의4(정보기술부문 사고보고)
- d. 정보통신망법 제48조의3(침해사고의 신고 등)

II. 침해사고 대응 체계 및 조직

1. 침해사고 대응 체계도



2. 침해사고 대응 조직 구성

침해사고 대응팀의 구성 및 역할은 다음과 같다.

관련부서		주요 역할
보안팀	CISO	- 침해사고 대응팀장 - 침해사고 대응 업무 총괄 - 금융당국 침해사고 신고 및 보고
	팀원	- 침해사고 분석 및 대응 - 대외 유관기관 협력체계 가동 - 침해사고 원인 및 조치방안 공유
	보안관제	- 침해사고 탐지 및 모니터링 (24*7*365)
법무팀		- 법률상 대응방안 검토 - 침해사고 관련 디지털 증거(포렌식 등) 수집 및 법적 대응
MA/MBP/Platform 팀 (Product 부문)		- 침해사고 관련 IT 업무지원 • 서버, 네트워크 장비 등 성능 및 용량 모니터링 • 시스템 및 데이터 복구방안 수립 및 복구수행 • 정보처리시스템 유지보수 업체와의 협력
마케팅팀/서비스운영		- 침해사고 관련 미디어(언론사 등) 대응 - 고객 대응
피해발생부서		- 홈페이지/모바일 앱 안내문 게시 - 핵심 업무 서비스 정상화를 위한 내부 협조 등

3. 비상연락체계

침해사고에 대비한 금융당국, 유관기관 및 유지보수 업체 등 비상연락망은 다음과 같다.

구 분		담당업무	담당자	연락처
CISO		침해사고 대응팀장	서홍석	010-1234-5678
침해사고 대응팀	정보보안팀	침해사고 분석/대응	주상욱	010-7703-0586

구 분		담당업무	담당자	연락처
		침해사고 협조/공유	이윤혁	010-2719-1757
		통합 보안관제	박정인(싸이버원)	010-2221-3266
	Compliance	침입자에 대한 법적 대응	박수영	010-9196-7146
	MA/MBP/Platform (product 부문)	성능 및 용량 모니터링	서동진	010-3489-7667
		시스템 및 데이터 복구	백지훈	010-8969-6354
	마케팅팀	미디어 대응	김태우	010-6789-4344
	서비스 운영팀	고객 대응	이아람	010-4349-1201
유지보수	보안장비	방화벽 (Fortigate)	박종훈(오픈베이스)	010-4447-1205
		웹방화벽(AWS WAF)	박정인(싸이버원)	010-2221-3266
	네트워크	인터넷 라우터	백지훈	010-8969-6354
	서버	중요 서버	서동진	010-3489-7667
	DB	중요 DB	백지훈	010-8969-6354
회선사업자 (ISP)	KT	네트워크 장애 대응	장영일	02-3484-7000 (koreachang01@daum.net)
금융당국	금융위원회	침해사고 관련 관리·감독	금융위원회	02-2100-2500
	금융감독원	침해사고 관련 관리·감독	금융감독원	1332
유관기관	금융보안원	침해사고 대응 협력	금융보안원	02-3495-9000
	한국인터넷진흥원	침해사고 대응 협력	한국인터넷진흥원	118

III. 침해사고 탐지 및 분석

1. 침해사고 신고 및 접수

1. 최초로 침해사고 인지자는 즉시 소속팀 리더 및 보안팀에게 다음 사항에 대해 보고한다.
2. 침해사고로 판단한 근거 또는 침해 유형
3. 사고 인지 경로 : 자체 탐지, 언론보도, 감독기관 연락 등
4. 침해사고 사실을 보고받은 보안팀은 MA/MBP 등 관련 피해발생부서의 피해 정도를 파악하고, 다음과 같은 침해 공격 유형이 의심되는 경우 'VI. 침해사고 유형별 대응 시나리오'를 참고하여 최종 침해 사고 여부를 판단한다.

- a. 악성코드 공격
 - b. 분산 서비스거부(DDoS) 공격
 - c. 비인가자 접근에 의한 공격
5. 보안팀은 침해사고 심각도가 '경계' 단계 이상이라고 판단되는 경우 CISO에게 해당 내용을 즉시 보고한다.

2. 침해사고 대응조직 소집

1. CISO는 '18. 장애(사고)보고서'에 따라 공격 유형 및 피해 규모 등을 고려하여 침해사고 대응 구성·운영여부를 결정한다.
2. 보안팀은 침해사고 대응팀을 구성하는 경우 '비상연락체계' 내 구성원에게 연락하여 소집한다.

3. 침해사고 신고 및 보고

1. CISO는 침해사고 심각도가 '경계' 단계 이상인 경우 침해사고 관련 내용을 대표이사에게 보고한다.
2. CISO는 침해사고 심각도가 '심각' 단계이고 「침해사고 대응 지침」 '제17조(정보기술부문 및 전자금융 사고 보고)'에 따른 금융감독원 보고 대상 침해사고인 경우, 다음과 같은 절차에 따라 보고한다.
 - a. '18. 장애(사고)보고서'를 보안팀에게 작성 지시
 - b. 대표이사에게 침해사고 관련 내용 보고
 - c. 금융감독원 전자금융사고대응시스템(Electronic Financial Accident Response System : EFARS)으로 사고 보고
3. 금융감독원 사고보고는 최초보고, 중간보고 및 종결보고로 구분하며, 절차와 방법은 「침해사고 대응 지침」 '제17조(정보기술부문 및 전자금융 사고 보고) 제 6항'을 따른다.
4. CISO는 침해사고 대응 관련하여 협조가 필요하다고 판단될 경우 금융보안원, 한국인터넷진흥원 등의 전문기관의 도움을 요청한다.
5. 침해사고 대응 과정에서 개인정보 유출 사실이 발견되는 경우에는 「개인(신용)정보 유출 대응 매뉴얼」에 따라 별도 대응한다.

4. 침해사고 상황전파

1. 침해사고 대응팀장 주관 하에 이메일, 그룹웨어 등을 활용하여 내부 임직원에게 침해사고 관련 주요 내용을 전파한다.
2. 침해사고 대응팀은 대외적으로 상황 전파 또는 대응이 필요하다고 판단될 경우 다음 부서에서 침해사고 관련 주요 내용을 전파한다.
 - a. 마케팅팀: 침해사고 관련 미디어(언론사 등) 대응
 - b. 피해발생부서: 홈페이지/모바일 앱 안내문 게시

IV. 침해사고 대응 및 복구

1. 침해사고 대응 조치

1. 보안팀

- a. 통합보안관리·침입차단·침입탐지시스템 등을 통해 공격자의 IP주소 등 시스템 정보를 수집하고, 다음과 같은 대응 조치를 실시한다.
 - i. 1단계 : 침해시도 탐지 시 위협이 된다고 판단되는 IP차단
 - ii. 2단계 : 침해시도 IP가 확인될 경우 해당 소유자에게 고의여부 확인
 - iii. 3단계 : 법적 대응을 위한 디지털 증거(포렌식 등) 확보
- b. 보안팀은 침해사고 유형이 다음과 같은 경우 'VI. 침해사고 유형별 대응 시나리오'을 참고하여 대응 조치를 실시한다.
 - i. 악성코드 공격
 - ii. 분산 서비스거부(DDoS) 공격
 - iii. 비인가자접근에 의한 공격
- c. 보안팀은 고의성이 있거나 위협이 된다고 판단되는 경우 해당 기관 및 개인을 통합 보안관리시스템의 블랙리스트에 등록·관리한다.

2. MA/MBP/Platform (Product부문)

3. MA/MBP는 침해사고 대응팀과 협의 하에 다음과 같은 대응 조치를 실시한다.

- a. 재해복구 현황 점검 및 가동 준비
- b. 핵심 시설·업무·인력·대체자원 등 현황 파악
- c. 피해시스템 복구 예상 시간 파악

4. MA/MBP는 전산실 문제 발생 시 '백업 및 복구 계획(작성 진행 중)'IT재해복구 계획에 따라 재해복구시스템으로 전환하여 가동한다.

5. 마케팅팀/서비스운영팀

- a. 마케팅팀은 침해사고 대응팀과 협의 하에 다음과 같은 대응 조치를 실시한다.
 - i. 대고객 앞 홈페이지를 통한 홍보 활동
 - ii. 대외 언론 등을 통한 홍보 활동

6. 법무팀

- a. 법무팀은 침해사고 대응팀과 협의 하에 다음과 같은 대응 조치를 실시한다.
 - i. 침입자에 대한 법정 대응
 - ii. 디지털 증거(포렌식 등) 확보를 위한 법적 지원

2. 침해사고 복구

1. 침해사고 대응팀은 다음과 같은 절차에 따라 피해시스템을 복구한다.

구분	내용
피해복구 범위 결정	• (단순 데이터복구) 침해된 시스템의 데이터만 손상 발생 • (소프트웨어 복구) 침해된 시스템의 프로그램 및 운영체제에 단순 오류 발생 • (시스템 재설치) 침해된 시스템의 운영체제에 복구가 불가능 심각한 오류 발생 • (하드웨어 교체) 침해된 시스템의 하드웨어 손실 발생
피해복구 우선순위 결정	• 침해된 시스템이 두 개 이상인 경우, 이들 대상에 대한 복구 우선순위 결정 • 즉시 조치해야 할 복구 내용과 중장기적인 계획에 의해 수행해야 할 복구내용 결정
피해 복구	• (단순 데이터복구) - 침해사고 발생 전 백업했던 데이터로 복구 - 백신 프로그램을 이용한 악성코드 탐지 및 치료 • (소프트웨어 복구) - 소프트웨어 패치를 이용한 공격에 이용된 취약점 제거 - 응용프로그램 재설치 - 운영체제 손상 시 운영체제 복구(CD/레파지토리/스냅샷) • (시스템 재설치) - 운영체제 재설치(CD/레파지토리/스냅샷) - 필요한 응용프로그램 설치 - 백업한 자료를 이용한 데이터 복원 - 시스템 재설치 완료 후 정상상태 복귀 확인 • (하드웨어 교체) - 파손된 하드웨어 부품 교체

1. 침해사고 대응팀은 다음과 같은 절차로 시스템 보완작업을 실시 할 수 있다.

- a. 패치 업그레이드
- b. CERT 기술권고문 등 관련 자료를 참고하여 조치
- c. 해킹방지 등 보안도구들을 설치
- d. 네트워크 방화벽 시스템 설정 검토
- e. 사용자 패스워드 교체
- f. 네트워크 재접속 및 운영 시작

3. 침해사고 기록 및 보고

1. 침해사고 대응팀은 협조 하에 보안팀은 '<침해사고(장애) 대응 결과보고서>'를 작성하여 침해사고 대응팀장에게 보고한다.
 - a. 보안팀은 작성된 침해사고(장애) 대응 결과보고서를 1년 이상 보존한다.

V. 침해사고 종결 및 보고

1. 상황 종결

1. 침해사고 종결은 침해사고 관련 보고서 및 기타 정보를 종합하여 대응팀장이 대표이사에게 상황 종결에 대한 보고 후 최종 결정한다.

- a. 침해사고 대응팀은 내부 임직원 및 유관기관을 대상으로 침해 상황 종결에 대한 상황을 전파한다.

2. 후속 조치

1. 대외 대응

- a. 침해사고 대응팀은 마케팅팀과 협의하여 침해 상황 종결 관련 보도 자료를 작성하여 언론 등 대외 홍보를 수행한다.

2. 지속적 개선

- a. 침해사고 대응팀은 보안팀과 협의하여 침해사고 재발방지 대책을 수립하고, 임직원에게 공유한다.
- b. 보안팀은 침해사고 재발방지 대책 또는 침해사고 대응 훈련결과에 따라 연 1회 이상 본 매뉴얼의 실효성 및 적정성을 검토하여 최신 상태로 유지·관리한다.

VI. 침해사고 유형별 대응 시나리오

1. 침해사고 유형

침해사고 대응팀은 다음과 같은 침해사고 유형에 대해 신속히 대응한다.

구분	내용
악성코드 공격	악성코드, 웜, 트로이목마, 백도어, 봇(Bot), 스파이웨어 등이 사용자 동의 없이 컴퓨터에 설치되어 사용자의 정보를 탈취하거나 컴퓨터를 오작동 시키고 네트워크를 마비시킬 수 있는 악의적인 행위를 의미
분산 서비스거부 공격(DDoS)	- 시스템에 과도한 부하를 유발하여 정상적인 서비스를 차단하거나, 성능을 저하시키는 행위를 의미 - DDoS 공격은 TCP 프로토콜을 이용하여 요청메시지에 대한 응답메시지를 보내지 않음으로써 피해시스템의 TCP 세션을 불안정한 상태로 연결하여 수용 능력을 포화시켜 피해시스템의 서비스를 불가능하게 만든다. 공격자는 소스 IP정보를 위조하거나 봇과 같은 악성코드에 의해 감염된 시스템을 이용함으로써 자신의 위치를 노출시키지 않음
비인가접근에 의한 공격	- 네트워크, 시스템, 응용프로그램, 데이터 또는 기타 자원 등에 인가를 받지 않은 자가 논리적 또는 물리적으로 불법 접근하는 공격 유형을 의미 - 공격자는 자신이 직접 해킹을 시도할 수도 있고, 악성코드를 이용하여 사용자의 중요정보를 자동으로 수집한 후 정상적인 방법으로 해킹을 시도할 수도 있음

2. 침해사고 유형별 대응 시나리오

1. 악성코드 공격

단계		시나리오
침해사고 탐지 및 분석	침해사고 신고 및 접수	다음과 같은 악성코드 공격에 의한 증상을 최초로 발견한 자는 즉시 소속팀 리더 및 보안팀에게 관련 내용을 보고하고, 감염이 의심되는 단말기 및 시스템을 네트워크에서 분리

단계		시나리오
		1. 백신 소프트웨어의 악성코드 감염 경고 발생 2. 파일 또는 프로그램의 삭제 및 손상 1) 문서 열람 또는 프로그램 실행 시 오류 발생 2) 보안관련 프로그램 실행 시 자동종료 3. 특정 프로세스의 비정상적인 작동 1) 해당 프로세스의 CPU 사용량 증가 2) 피해시스템의 네트워크 사용량 증가 3) 출처가 불분명한 원격시스템과 피해시스템간의 네트워크 연결 탐지 4. 의도하지 않은 대화상자 출현 1) 화면에 이상한 메시지나 그림 출현 2) 인터넷 사용 시 의도하지 않은 웹 사이트로 연결
	침해사고 대응조직 소집	5. 침해사고 대응팀 구성·운영여부 결정 및 구성원 소집 <i>* 해당 절차는 'III. 침해사고 탐지 및 분석' 내용과 동일</i>
	침해사고 신고 및 보고	6. 침해사고 심각도에 따라 대표이사, 금융감독원 보고 수행 <i>* 해당 절차는 'III. 침해사고 탐지 및 분석' 내용과 동일</i>
	침해사고 상황전파	7. 침해사고 대응팀은 침해 상황에 대해 내부 임직원 및 대외 전파 <i>* 해당 절차는 'III. 침해사고 탐지 및 분석' 내용과 동일</i>
침해사고 대응 및 복구	침해사고 대응 조치	8. 보안팀은 악성코드 공격에 대해 다음과 같은 대응 조치 실시 1) 감염 시스템 분리 및 전체 안티바이러스 검사 i) 감염된 호스트 네트워크 분리 ii) 안티바이러스 전체검사 - Desktop/Laptop: 엑소스피어 전체검사 2) 증상 확인 i) 트로이목마 및 백도어에 대한 포트 스캐닝 수행 ii) 사용하지 않는 계정 및 숨겨진 계정 확인 - Windows: 관리도구 > 컴퓨터 관리 > 로컬사용자 및 그룹 > 사용자 - Linux/UNIX: /etc/passwd 확인 iii) 시스템 로그 변조 유무 확인 - Windows: 관리도구 > 컴퓨터 관리 > 이벤트뷰어 확인 - Linux/UNIX: /var/log/secure, message 확인 iv) 비정상 프로세스 확인 v) 악성코드 유포 경로 확인 3) 감염(유입) 경로 차단 i) 방화벽에서 유입 차단 규칙 적용 ii) 내부에서 외부로 나가는 패킷 주기적 검토, 차단 iii) E-mail 서버 및 프로그램을 대상으로 차단 규칙 적용 4) 바이러스 치료(백신을 이용한 치료, 수동 파일 제거) 5) 공격에 이용된 취약점 제거 i) 보안 최신 패치 ii) 백신 프로그램 운용 iii) 공유 폴더 제거 또는 패스워드 변경 <i>* 그 외 절차는 'IV. 침해사고 대응 및 복구' 내용과 동일</i>
	침해사고 복구	9. 침해사고 대응팀은 다음과 같이 피해시스템 복구 1) 피해복구 범위 결정 2) 피해복구 우선순위 결정 3) 피해 복구

단계		시나리오
		※ 해당 절차는 'IV. 침해사고 대응 및 복구' 내용과 동일
	침해사고 기록 및 보고	10. 보안팀은 침해사고(장애) 대응 결과보고서 작성 및 침해사고 대응팀장 보고하고, 결과보고서에 대해 1년간 보존 ※ 해당 절차는 'IV. 침해사고 대응 및 복구' 내용과 동일
침해사고 종결 및 보고	상황 종결	11. 침해사고 대응팀은 침해사고 심각도에 따라 상황 종결 여부 결정 ※ 해당 절차는 'IV. 침해사고 대응 및 복구' 내용과 동일
	후속조치	12. 커뮤니케이션팀은 필요 시 보도 자료를 작성하여 언론 등 대외 홍보 13. 침해사고 대응팀장은 브리핑 계획 수립 14. 재발방지대책 수립 및 연 1회 매뉴얼 개정 활동 수행 ※ 해당 절차는 'IV. 침해사고 대응 및 복구' 내용과 동일

2. 분산 서비스거부 공격(DDoS)

단계		시나리오
침해사고 탐지 및 분석	침해사고 신고 및 접수	1. 다음과 같은 DDoS 공격에 의한 증상을 최초로 발견한 자는 즉시 소속팀 리더 및 보안팀에게 관련 내용 보고 1) 침입탐지시스템, 침입차단시스템 등 정보보호시스템에서 DDoS 공격 침입시도 탐지 2) 백신 소프트웨어에 의한 DDoS 공격 도구 발견 3) 특정 서버의 서비스 중단 4) 과도한 트래픽 집중으로 인하여 소프트웨어/하드웨어 오류가 발생되어 서비스 중단 5) 네트워크 속도 저하 i) 피해시스템의 네트워크 사용량 폭증으로 인한 네트워크 속도 저하 ii) 출처가 불분명한 다수의 원격시스템과 피해 시스템 간의 네트워크 연결 탐지 6) 네트워크 트래픽의 이상패턴 발견 i) 패킷의 발신/수신 IP주소가 없거나, 존재하지 않는 IP주소로 변조 ii) 일정한 패턴의 발신/수신 IP주소를 갖는 일련의 트래픽 발견 iii) 비대칭형 네트워크 트래픽 패턴 다수 발생
	침해사고 대응조직 소집	2. 침해사고 대응팀 구성·운영여부 결정 및 구성원 소집 ※ 해당 절차는 'III. 침해사고 탐지 및 분석' 내용과 동일
	침해사고 신고 및 보고	3. 침해사고 심각도에 따라 대표이사, 금융감독원 보고 수행 ※ 해당 절차는 'III. 침해사고 탐지 및 분석' 내용과 동일
	침해사고 상황전파	4. 침해사고 대응팀은 침해 상황에 대해 내부 임직원 및 대외 전파 ※ 해당 절차는 'III. 침해사고 탐지 및 분석' 내용과 동일
침해사고 대응 및 복구	침해사고 대응 조치	5. 보안팀은 DDoS 공격에 대해 다음과 같은 대응 조치 실시 1) DDoS 공격 추적·차단 i) 근원지 IP와 동일한 tcp service scan, udp service scan 등의 이벤트 확인 ii) 동일한 근원지 IP에서 취약점 공격 이벤트 확인 iii) 공격 특성에 맞게 라우터나 스위치에 CAR 또는 ACL을 설정하여 해당

단계		시나리오
		공격 차단 iv) 공격 특성에 맞게 침입차단시스템의 차단규칙을 설정하여 해당 공격 차단 2) 정보통신서비스제공자(ISP) 차단규칙을 통한 공격차단 및 추적 i) 외부 호스트로부터의 DDoS 공격으로 인하여 인터넷 라우터가 정지 및 오동작하는 경우 공격 차단 및 공격자 추적 등을 해당 ISP에 요청 3) 피해시스템의 위치 재배치 및 중요자료 백업 i) DDoS 공격 대응전략이 효과가 없는 경우, 해당 호스트를 다른 IP주소로 대체 ii) 피해시스템의 빠른 복원을 위하여 가능한 빨리 백업도구를 이용하여 저장테이프 등 보조기억장치에 시스템의 데이터를 백업 iii) DDoS공격 대응 전략이 효과가 없고 공격에 대한 피해가 크다고 판단될 경우, 공격대상 네트워크를 분리한다. 4) 약용되고 있는 보안취약점 또는 결함 제거 i) 취약점이 존재하는 시스템의 서비스를 이용하는 DDoS 공격의 경우, 해당 서비스 포트로 패킷이 유입되지 않도록 침입차단시스템이나 라우터에서 차단규칙을 설정하여 패킷 차단 ii) 서버의 경우 TCP/IP 스택 설정을 강화하고 공격정도에 따라 설정 강도를 높여 공격 대응 iii) 유사 공격의 재발을 방지하기 위하여 보안패치 되지 않은 시스템은 해당 취약점을 각 운영체제별 패치사이트에서 패치를 다운받아서 설치 ※ 그 외 절차는 'IV. 침해사고 대응 및 복구' 내용과 동일
	침해사고 복구	6. 침해사고 대응팀은 다음과 같이 피해시스템 복구 1) 피해복구 범위 결정 2) 피해복구 우선순위 결정 3) 피해 복구 ※ 해당 절차는 'IV. 침해사고 대응 및 복구' 내용과 동일
	침해사고 기록 및 보고	7. 보안팀은 침해사고(장애) 대응 결과보고서 작성 및 침해사고 대응팀장 보고하고, 결과보고서에 대해 1년간 보존 ※ 해당 절차는 'IV. 침해사고 대응 및 복구' 내용과 동일
침해사고 종결 및 보고	상황 종결	8. 침해사고 대응팀은 침해사고 심각도에 따라 상황 종결 여부 결정 ※ 해당 절차는 'IV. 침해사고 대응 및 복구' 내용과 동일
	후속조치	9. 커뮤니케이션팀은 필요 시 보도 자료를 작성하여 언론 등 대외 홍보 10. 침해사고 대응팀장은 브리핑 계획 수립 11. 재발방지대책 수립 및 연 1회 매뉴얼 개정 활동 수행 ※ 해당 절차는 'IV. 침해사고 대응 및 복구' 내용과 동일

3. 비인가접근에 의한 공격

단계		시나리오
침해사고 탐지 및 분석	침해사고 신고 및 접수	1. 다음과 같은 비인가접근에 의한 공격 증상을 최초로 발견한 자는 즉시 소속팀 리더 및 보안팀에게 관련 내용 보고

단계		시나리오
		1) F/W, IPS 등 정보보호시스템에서 비인가접근에 의한 침입시도 탐지 2) 비정상적인 사용자 계정 발견 i) 동시에 다양한 원격지로부터 접속 중인 사용자 계정 발견 ii) 관리자 수준의 새로운 사용자 또는 그룹 계정 발견 3) 비정상적으로 동작하는 프로그램 발견 i) 레지스트리 혹은 시작 파일 목록 등에서 정체불명의 프로그램 리스트 발견 ii) 비정상적으로 실행중인 프로세스 발견 4) 데이터 위·변조 및 삭제 흔적 발견 i) 중요자료의 위·변조 및 삭제 흔적 발견 ii) 문서, 프로그램 등의 권한설정 및 시간 변경 iii) 시스템, 중요설정파일의 변경사항 발견 iv) 시스템 부하, 네트워크 사용량, 로그 기록량, 파일시스템 사용량 등 5) 시스템운용상의 심각한 변화 발생 i) 타 기관으로부터 공격 경유지 등으로 이용되고 있다는 사실을 통지 ii) 특정 호스트에 대한 경유지 이용으로 유추할 수 있는 네트워크 트래픽 탐지
	침해사고 대응조직 소집	2. 침해사고 대응팀 구성·운영여부 결정 및 구성원 소집 <i>* 해당 절차는 'III. 침해사고 탐지 및 분석' 내용과 동일</i>
	침해사고 신고 및 보고	3. 침해사고 심각도에 따라 대표이사, 금융감독원 보고 수행 <i>* 해당 절차는 'III. 침해사고 탐지 및 분석' 내용과 동일</i>
	침해사고 상황전파	4. 침해사고 대응팀은 침해 상황에 대해 내부 임직원 및 대외 전파 <i>* 해당 절차는 'III. 침해사고 탐지 및 분석' 내용과 동일</i>
침해사고 대응 및 복구	침해사고 대응 조치	5. 보안팀은 비인가접근에 의한 공격에 대해 다음과 같은 대응 조치 실시 1) 피해시스템을 격리 또는 관련 서비스 중지 i) 시스템의 추가적 피해 및 피해 상황 확산을 방지하기 위해 가능한 사고 시스템을 물리적, 논리적으로 분리 ii) 비인가 접근공격 근원지를 식별하고, 라우터, 스위치, 침입차단시스템의 차단규칙 및 서버의 네트워크 차단규칙 설정을 통하여 사후 비인가 접근 차단 2) 로그 자료 백업 i) 비인가 접근공격 근원지를 식별하고, 원인 파악을 위한 중요한 단서로 사용될 로그 자료를 안전하게 백업 및 보관 3) 비인가 접근공격에 사용된 계정 제거 i) 공격에 이용된 계정을 식별하고, 윈도우 시스템과 유닉스 시스템의 사용자 계정을 사용 중지 또는 제거 ii) 내부 사용자가 외부 조직을 공격하는 것과 같은 부적절한 행위를 발견할 경우, 내부 절차에 따라 징계 조치 iii) 외부에서 내부 네트워크로 비인가 접근공격 시도를 발견한 경우, 유관기관과 협조하여 불법접근 사용자 계정의 제거 또는 점검 <i>* 그 외 절차는 'IV. 침해사고 대응 및 복구' 내용과 동일</i>
	침해사고 복구	6. 침해사고 대응팀은 다음과 같이 피해시스템 복구 1) 피해복구 범위 결정 2) 피해복구 우선순위 결정 3) 피해 복구 <i>* 해당 절차는 'IV. 침해사고 대응 및 복구' 내용과 동일</i>

단계		시나리오
	침해사고 기록 및 보고	7) 보안팀은 침해사고(장애) 대응 결과보고서 작성 및 침해사고 대응팀장 보고하고, 결과보고서에 대해 1년간 보존 ※ 해당 절차는 'IV. 침해사고 대응 및 복구' 내용과 동일
침해사고 종결 및 보고	상황 종결	8) 침해사고 대응팀은 침해사고 심각도에 따라 상황 종결 여부 결정 ※ 해당 절차는 'IV. 침해사고 대응 및 복구' 내용과 동일
	후속조치	9) 커뮤니케이션팀은 필요 시 보도 자료를 작성하여 언론 등 대외 홍보 10) 침해사고 대응팀장은 브리핑 계획 수립 11) 재발방지대책 수립 및 연 1회 매뉴얼 개정 활동 수행 ※ 해당 절차는 'IV. 침해사고 대응 및 복구' 내용과 동일

VII. 참고사항

관련 법규 상세 내용

관련 법규	상세내용
전자금융감독규정 제37조의5(정보기술부문 및 전자금융 사고보고)	① 금융회사 및 전자금융업자는 정보기술부문 및 전자금융과 관련된 사고에 관하여 다음 각 호를 준수하여야 한다. 1. 사고의 유형 분류, 처리단계, 조치방법, 영향도 및 심각도 평가 방법 등이 포함된 절차를 마련 운영 2. 금융감독원장이 정하는 사고가 발생한 경우에는 지체없이 금융감독원장에게 보고 ② 금융회사 및 전자금융업자는 제1항제2호에 따른 사고보고를 고의로 지연하거나 숨긴 자에 대하여 소정절차에 따라 징계 등 필요한 조치를 취하여야 한다. ③ 금융감독원장은 제1항제2호에 따라 보고 받은 내용을 지체없이 금융위원장에게 보고하여야 한다. ④ 제1항제2호의 사고보고와 관련하여 사고보고 대상, 절차 및 방법 등 세부사항은 금융감독원장이 정하는 바에 따른다.
전자금융감독규정 제37조의6(침해사고대응기관 지정 및 업무범위)	① 침해사고에 대응하기 위한 침해사고대응기관은 다음 각 호의 자로 한다. 1. 금융보안원 2. 삭제 3. 금융위원장이 지정한 자 ② 침해사고대응기관은 다음 각 호의 업무를 수행한다. 1. 침해사고에 관한 정보의 수집·전파를 위한 정보공유체계의 구축 2. 침해사고의 예보·경보 발령내용의 전파 3. 침해사고의 원인분석과 신속한 대응 및 피해 확산방지를 위해 필요한 조치 4. 금융회사 및 전자금융업자와 관련된 해킹 등 전자적 침해행위 정보를 탐지·분석하여 즉시 대응 조치를 하기 위한 기구(이하 "금융권 통합 보안관제센터"라 한다)의 운영 5. 금융회사 및 전자금융업자의 침해사고 예방, 대응을 위한 자율기준의 마련 및 운영 ③ 금융위원장은 제37조의4 및 제37조의5제3항에 따라 보고받은 내용으로서 전자적 침해행위가 원인이거나 원인으로 의심되는 경우 사고 조사 및 피해확산 방지를 위해 침해사고대응기관을 포함하여 침해사고조사단을 구성·운영할 수 있다. ④ 금융위원장은 제2항에 따른 침해사고 긴급대응을 위한 침해사고대응기관의 업무 수행 또는 제3항에 따른 침해사고 원인분석 및 긴급조치를 위하여 금융회사 및 전자금융업자, 전자금융보조업자에 협조를 요청할 수 있다. ⑤ 금융회사 및 전자금융업자는 침해사고에 대한 대응능력 확보를 위하여 연 1회 이상 침해사고 대응 및 복구훈련 계획을 수립·시행하여야 하며 그 계획 및 결과를 침해사고 대응기관의 장에게 제출하여야 한다. 다만 다음 각 호의 어느 하나에 해당하는 금융회

관련 법규	상세내용
	사는 그러하지 아니한다. 1. 법 제2조제3호가목의 금융회사 중 신용협동조합 2. 법 제2조제3호다목·라목의 금융회사 3. 시행령 제2조제4호부터 제6호까지의 조합 4. 시행령 제5조제2항의 요건을 충족한 금융회사 ⑥ 금융위원장은 침해사고대응기관의 장으로 하여금 침해사고 대응·복구 및 훈련결과를 점검하고 보완이 필요하다고 판단되는 경우 개선·보완을 요구할 수 있다. ⑦ 금융위원장은 침해사고대응기관의 장으로 하여금 시행령 제11조의6제1항제4호에 따른 보안취약점 통보를 위하여 금융회사 및 전자금융업자가 사용하고 있는 소프트웨어에 대한 조사·분석을 실시하게 할 수 있다.
전자금융감독규정시행세칙 제7조의4(정보기술부문 사고보고)	① 규정 제37조의5제4항에 따라 감독원장이 정하는 사고보고 대상은 다음 각 호와 같다. 1. 정보처리시스템 또는 통신회선 등의 장애로 인하여 다음 각 목 중 하나에 해당하는 사고가 발생한 경우 가. 전자금융업무 지연·중단 시간이 30분 이상인 경우 나. 전자금융업무 지연·중단 시간이 10분 이상이고 해당 전자금융서비스 가입자가 1만명 이상인 경우 2. 전산자료 또는 프로그램의 조작 및 오류와 관련된 사고가 발생한 경우 3. 전자적 침해행위로 인해 정보처리시스템에 사고가 발생하거나 이로 인해 이용자가 금전적 피해를 입었다고 금융회사 또는 전자금융업자에게 통지한 경우 4. 법 제9조제1항의 규정에서 정하는 사고가 발생한 경우 ② 제1항에도 불구하고 다음 각 호에 해당하는 경우는 사고보고 대상에서 제외한다. 1. 제1항제1호에 해당하는 사고 중 영업점 내 장애의 경우 1개 영업점에 국한된 전자금융업무 중단·지연 2. 제1항제1호에 해당하는 사고 중 이용자에게 단순 정보 제공을 위한 공개용 웹서버 등의 장애 또는 금융상품 및 서비스와 무관한 장애 3. 법 제9조제1항제1호 또는 제3호의 사고가 발생하였으나 사고금액이 100만원 미만인 경우 ③ 금융회사 및 전자금융업자는 제1항의 사고가 발생한 경우 별지 제2호서식 별첨1에 따라 지체 없이 보고하여야 하며, 정당한 사유없이 그 사실을 안 때부터 24시간을 경과하여서는 아니된다. 다만, 법 제9조제1항제1호의 사고 중 사고금액이 3억원 미만인 사고의 경우 매월 발생한 사고를 익월 15일까지 별지 제2호서식 별첨2에 따라 일괄 보고할 수 있다. ④ 제3항에 따른 사고보고는 최초보고, 중간보고 및 종결보고로 구분한다. 1. 최초보고 : 사고를 인지 또는 발견한 때로부터 24시간 이내에 전자금융사고대응시스템(Electronic Financial Accident Response System : EFARS)으로 보고한다. 단, 전산장애, 금융정보교환망 미연결 등 부득이한 경우에는 서면, 팩시밀리 또는 유선으로 보고할 수 있으며, 이 경우에 전자금융사고대응시스템(EFARS)으로 보고가능한 즉시 전자금융사고대응시스템(EFARS)으로 보고한다. 2. 중간보고 : 제1호의 최초보고 후 사고내용을 보완할 필요가 있는 경우에는 즉시 중간보고를 하여야 하며, 제3호의 조치완료 시까지 2월 이상 소요될 경우에는 인지·발견 일로부터 2월 이내 및 종결 시까지 매 6월마다 제1호의 방법에 따라 보고한다. 다만, 최초보고 후 조치완료 시까지 2월 미만이 소요될 경우에는 중간보고를 생략할 수 있다. 3. 종결보고 : 사고발생 원인 파악 및 조치, 재발방지 대책 마련 등이 완료(사고금액에 대한 배상책임이 있는 경우에는 배상조치까지 포함)되어 정상적인 업무를 수행하게 된 때 제1호의 방법에 따라 보고한다. 다만, 최초보고 시 조치가 이미 완료된 경우에는 종결보고를 생략할 수 있다. ⑤ 감독원장은 금융회사 및 전자금융업자 정보기술부문의 사고보고 등을 전담할 비상

관련 법규	상세내용
	연락 담당자를 회사별로 지정할 수 있다. ⑥ 금융회사 및 전자금융업자는 비상연락 담당자가 제5항에 따라 지정되거나 변경된 경우에는 제4항제1호에서 정한 보고방법에 따라 감독원장에게 즉시 보고하여야 한다. ⑦ 감독원장은 제4항에 따라 보고 받은 내용이 제1항제3호의 사고 발생인 경우에는 규정 제37조의6제1항 각 호에 따른 침해사고대응기관에도 알려야 한다.
정보통신망법 제48조의3(침해사고의 신고 등)	① 정보통신서비스 제공자는 침해사고가 발생하면 즉시 그 사실을 과학기술정보통신부장관이나 한국인터넷진흥원에 신고하여야 한다. 이 경우 정보통신서비스 제공자가 이미 다른 법률에 따른 침해사고 통지 또는 신고를 했으면 전단에 따른 신고를 한 것으로 본다. ② 과학기술정보통신부장관이나 한국인터넷진흥원은 제1항에 따라 침해사고의 신고를 받거나 침해사고를 알게 되면 제48조의2제1항 각 호에 따른 필요한 조치를 하여야 한다. ③ 제1항 후단에 따라 침해사고의 통지 또는 신고를 받은 관계 기관의 장은 이와 관련된 정보를 과학기술정보통신부장관 또는 한국인터넷진흥원에 지체 없이 공유하여야 한다. ④ 제1항에 따른 신고의 시기, 방법 및 절차 등에 관하여 필요한 사항은 대통령령으로 정한다.

[illegible]